Dossier de synthèse

Analyse de risques EBIOS Risk Manager

Plateforme cloud hébergeant l'ERP et le CRM d'une PME de formation numérique

TP2 – EBIOS RM

Groupe : Nathan, Camille, Chloé

Version v9 – 13 octobre 2026

Sommaire

Clic droit sur le sommaire puis « Mettre à jour les champs » pour l'actualiser dans Word.

Codes utilisés dans l’analyse

Chaque élément de l’analyse porte un code unique, utilisé à l’identique dans le classeur, le dossier et la présentation. C’est ce qui permet de remonter d’un risque (R) jusqu’à la valeur métier (VM) qu’il menace.

Code	Élément	Onglet du classeur	Responsable
VM1 à VM4	Valeurs métier	Atelier 1 - Missions	Nathan
BS1 à BS8	Biens supports	Atelier 1 - Missions	Nathan
ER1 à ER12	Événements redoutés	Atelier 1 - ER	Nathan
SROV1 à SROV7	Couples source de risque / objectif visé	Atelier 2 - SROV	Chloé
PP1 à PPn	Parties prenantes	Atelier 3 - PP	Camille
SS1 à SSn	Scénarios stratégiques	Atelier 3 - SS	Nathan
SO1 à SOn	Scénarios opérationnels	Atelier 4 - SO	Camille
R1 à Rn	Risques	Atelier 5 - Risques	Chloé
M1 à Mn	Mesures du plan de traitement	Plan de traitement (partie 6)	Tous
H1 à Hn	Hypothèses	Journal d’hypothèses (annexe A)	Tous

1. Contexte, objet d'étude et périmètre

Rédaction : Chloé

1.1 L'organisation étudiée

L'étude porte sur une PME fictive de formation numérique, déjà analysée lors du TP MEHARI. Son activité consiste à vendre, organiser et délivrer des formations à des clients entreprises et à leurs apprenants. Elle dépend pour cela d'outils numériques hébergés dans le cloud et d'un prestataire d'infogérance qui administre une partie de son système d'information.

Le cas étant fictif, les volumes (chiffre d'affaires, nombre de clients et d'apprenants, effectifs) ne sont pas connus. Lorsque l'analyse en a besoin, nous posons une hypothèse explicite, tracée dans le journal d'hypothèses (annexe A).

1.2 Objet de l'étude

L'objet de l'étude est **la plateforme cloud qui héberge l'ERP et le CRM de la PME**, avec les composants sur lesquels elle repose :

- la plateforme d'hébergement cloud (IaaS) ;
- les serveurs d'application ERP et CRM et la base de données associée ;
- l'annuaire, qui gère les comptes et les droits d'accès ;
- les sauvegardes ;
- l'accès distant utilisé par le prestataire d'infogérance ;
- les postes de travail des utilisateurs et la messagerie, qui donnent accès à ces applications.

Ce périmètre correspond au cas proposé par le guide du TP. Il est cohérent avec le TP MEHARI : nous approfondissons ici, par une approche par scénarios, la partie du système d'information qui porte la relation client et la facturation.

1.3 Valeurs métier retenues

Quatre valeurs métier ont été retenues. Elles sont détaillées, avec leurs biens supports et leurs événements redoutés, en partie 2.

Code	Valeur métier	Nature	Ce qui en dépend
VM1	Gestion commerciale et relation client	Processus	Suivi des prospects, des clients et des contrats
VM2	Fichier clients et apprenants	Information	Données personnelles et de contact nécessaires à la vente et à la formation
VM3	Facturation et encaissement	Processus	Émission des factures, suivi des règlements, trésorerie
VM4	Planification des sessions de formation	Processus	Organisation des sessions, affectation des formateurs, information des apprenants

1.4 Exclusions

- **La plateforme de formation en ligne (LMS)** est exclue : elle a déjà été analysée dans le TP MEHARI, et l'inclure doublerait le périmètre sans apporter d'enseignement nouveau sur la chaîne ERP/CRM.
- **Les événements accidentels** (panne matérielle, sinistre, erreur de manipulation) ne font pas l'objet de scénarios : EBIOS Risk Manager se concentre sur les menaces intentionnelles. Ils sont couverts par le socle de sécurité (partie 2 bis), notamment pour les sauvegardes et la continuité.

1.5 Participants et cadre temporel

Le groupe a joué les rôles prévus par la feuille Organisation du classeur. La répartition du travail suit nos rôles du TP MEHARI :

Membre	Rôle dans l'étude	Ateliers portés
Nathan	Responsable métier et actifs	Atelier 1 (périmètre, événements redoutés), atelier 3 (scénarios stratégiques, mesures sur l'écosystème)
Camille	Responsable sécurité et scénarios	Atelier 1 (socle de sécurité), atelier 3 (parties prenantes), atelier 4 (scénarios opérationnels)
Chloé	Responsable synthèse et restitution	Atelier 2 (sources de risque), atelier 5 (traitement), dossier et présentation

Les cotations, la sélection des scénarios et les priorités ont été validées collectivement lors de trois réunions : une séance de cadrage commune et deux synchronisations.

Pour le cadre temporel, nous proposons le rythme de révision recommandé par la méthode : une revue complète du cycle stratégique (ateliers 1 à 3) tous les trois ans, et une revue du cycle opérationnel (ateliers 4 et 5) chaque année, ou plus tôt en cas d'incident majeur ou de changement de prestataire.

1.6 Méthode et échelles

L'analyse suit la méthode EBIOS Risk Manager de l'ANSSI (version 1.5, 2024) et ses cinq ateliers, saisis dans le classeur officiel. Les échelles utilisées sont celles de l'onglet Métriques, validées par le groupe avant toute cotation :

- **Besoins de sécurité** : disponibilité, intégrité, confidentialité et traçabilité, de 1 à 4.
- **Gravité** : de G1 (mineure) à G4 (critique, survie de l'organisation menacée).
- **Vraisemblance** : de V1 (la source de risque a très peu de chances d'atteindre son objectif) à V4 (elle va certainement l'atteindre).
- **Pertinence des sources de risque** : croisement de la motivation et des ressources, en trois niveaux (+, ++, +++).
- **Niveau de risque** : croisement gravité × vraisemblance selon la matrice de l'onglet Métriques, en quatre niveaux (faible, significatif, modéré, élevé). Elle est présentée en partie 6.1.

La vraisemblance est cotée en méthode expresse, directement sur chaque scénario opérationnel, approche recommandée par le guide pour un premier TP. Pour rendre la gravité concrète, nous l'avons traduite en seuils adaptés à la PME :

Niveau	Ce que cela signifie pour la PME
G1 Mineure	Gêne passagère, rattrapée dans la journée, sans perte financière ni donnée exposée.
G2 Significative	Mode dégradé quelques jours, retard de facturation limité, aucune donnée personnelle exposée.
G3 Grave	Activité fortement perturbée plus d'une journée, retard de facturation notable, ou données internes exposées.
G4 Critique	Arrêt prolongé de la facturation ou de la relation client, fuite de données personnelles (RGPD) ou fraude financière : la survie de la PME peut être en jeu.

1.7 Limites de l'analyse

- Le cas est fictif : aucune visite, aucun entretien et aucun audit technique n'ont été réalisés. Les constats sur les protections existantes sont des hypothèses ou des déclarations, jamais des faits vérifiés.

– Les cotations reposent sur le jugement du groupe, appuyé sur les fiches méthode de l'ANSSI et sur des sources publiques citées. Chaque hypothèse structurante est tracée dans le journal (annexe A).
– Le nombre de scénarios est volontairement limité pour pouvoir les justifier : l'analyse n'est pas un inventaire exhaustif des menaces.

2. Atelier 1 – Périmètre métier et événements redoutés

Rédaction : Nathan

2.1 Valeurs métier et besoins de sécurité

Quatre valeurs métier portent l'activité. Les besoins sont cotés de 1 à 4 en disponibilité (D), intégrité (I), confidentialité (C) et traçabilité (T), un seul jeu par valeur métier.

Code	Valeur métier	Nature	Besoins D/I/C/T	Responsable
VM1	Gestion commerciale et relation client — Gérer les prospects, clients, contrats, échanges commerciaux et le suivi de la relation client.	processus	D=3 ; I=4 ; C=4 ; T=3	Responsable commercial / Direction (interne)
VM2	Fichier clients et apprenants — Ensemble des données d'identification, de contact et de suivi nécessaires aux activités commerciales et de formation.	information	D=3 ; I=4 ; C=4 ; T=4	Responsable administratif / Responsable formation (internes)
VM3	Facturation et encaissement — Émettre les factures, suivre les règlements, traiter les impayés et assurer les opérations d'encaissement.	processus	D=4 ; I=4 ; C=4 ; T=4	Responsable administratif et financier / Direction (internes)
VM4	Planification des sessions de formation — Planifier les sessions, affecter les ressources et communiquer les informations nécessaires aux formateurs et apprenants.	processus	D=3 ; I=4 ; C=3 ; T=3	Responsable formation (interne)

2.2 Biens supports

Les valeurs métier reposent sur neuf biens supports. BS2 (serveur CRM) et BS9 (serveur ERP) sont distingués.

Code	Bien support	Description	Responsable
BS1	Plateforme IaaS cloud	Ressources cloud, réseau et services d'hébergement des serveurs ERP/CRM.	Hébergeur cloud PP2 ; pilotage contractuel et suivi par la Direction de la PME.
BS2	Serveur / application CRM	Application de gestion des prospects, clients, contrats et opportunités commerciales.	Infogérant PP1 pour l'exploitation ; PME responsable métier ; éditeur PP3 pour les correctifs applicatifs.
BS3	Base de données	Données clients, apprenants, contrats et données de facturation partagées.	Infogérant PP1 ; contrôle des habilitations et de la restauration par la PME.
BS4	Annuaire / gestion des droits	Comptes, authentification, groupes et droits d'accès aux applications.	Infogérant PP1 ; validation des droits et des départs par la PME.
BS5	Sauvegardes	Copies de sauvegarde des données et applications permettant la restauration.	Infogérant PP1 ; tests de restauration et contrôle par la PME.
BS6	Accès distant du prestataire	VPN ou accès d'administration utilisé par l'infogérant pour maintenir la plateforme.	Infogérant PP1 ; autorisation, MFA et contrôle contractuel par la PME.
BS7	Postes de travail	Ordinateurs des collaborateurs utilisés pour accéder au CRM, à l'ERP et à la	Responsabilité interne PME ; règles de sécurité et mises à

Code	Bien support	Description	Responsable
		messagerie.	jour à définir.
BS8	Messagerie	Boîtes de messagerie des collaborateurs, vecteur de communication et de hameçonnage.	Responsabilité de la PME, avec dépendance au fournisseur de messagerie PP4.
BS9	Serveur / application ERP	Application de facturation, coordonnées bancaires, règlements et encaissement.	Infogérant PP1 pour l'exploitation ; PME responsable métier ; éditeur PP3 pour les correctifs applicatifs.

2.3 Événements redoutés

Douze événements redoutés ont été cotés. Deux sont critiques (G4) : la fuite massive de données personnelles (ER6) et l'altération des coordonnées bancaires (ER8).

Événement redouté	Gravité	Justification
ER1 – Indisponibilité du CRM et des données commerciales pendant plusieurs jours, empêchant le suivi des prospects, clients et contrats.	G3	une indisponibilité de plusieurs jours bloque le suivi commercial et peut entraîner une perte d'opportunités, mais des procédures dégradées restent possibles.
ER2 – Altération des informations clients, contrats ou opportunités dans le CRM.	G3	des données commerciales fausses peuvent provoquer des erreurs contractuelles et nécessiter une reconstitution, avec un impact important mais récupérable.
ER3 – Divulgation non autorisée de données clients et d'informations commerciales.	G3	la divulgation porte atteinte à la confidentialité et à la confiance des clients, sans entraîner à elle seule l'arrêt durable de l'organisation.
ER4 – Indisponibilité du fichier clients et apprenants pendant plus d'une journée.	G3	l'indisponibilité du fichier perturbe fortement le suivi des apprenants ; une partie de l'activité peut néanmoins continuer avec des procédures manuelles.
ER5 – Altération ou suppression de données d'identification et de suivi des apprenants.	G3	l'altération impose de vérifier et reconstruire des dossiers et peut causer des erreurs administratives, mais une récupération reste envisageable.
ER6 – Divulgation massive de données personnelles de clients et d'apprenants.	G4	une fuite massive de données personnelles peut entraîner des obligations réglementaires, des plaintes, une perte durable de confiance et une atteinte majeure à l'image.
ER7 – Indisponibilité de l'ERP de facturation et des données d'encaissement.	G3	l'indisponibilité de l'ERP retarde facturation et encaissement et dégrade la trésorerie, sans rendre nécessairement toute activité impossible.
ER8 – Altération des montants, coordonnées bancaires ou statuts de règlement.	G4	l'altération de montants ou de coordonnées bancaires peut provoquer des paiements frauduleux, des pertes financières importantes et des litiges

Événement redouté	Gravité	Justification
		difficiles à réparer.
ER9 – Divulgation de données financières et comptables.	G3	la divulgation d'informations financières facilite la fraude ciblée et fragilise les relations commerciales, avec un impact sérieux mais circonscrit.
ER10 – Indisponibilité des données de planification des sessions.	G3	la perte du planning désorganise les sessions et les ressources ; l'impact est fort à court terme mais peut être limité par une planification manuelle.
ER11 – Altération des dates, horaires, salles ou affectations.	G3	la modification des dates ou affectations peut entraîner des sessions manquées et des conflits de ressources, mais les erreurs restent généralement corrigeables.
ER12 – Divulgation non autorisée des informations de planification et des participants.	G2	la divulgation du planning affecte la confidentialité, mais les informations sont moins sensibles que les données financières ou les dossiers clients et l'activité peut continuer.

2 bis. Socle de sécurité

Rédaction : Camille

Quatre référentiels s'appliquent à l'objet de l'étude. Chaque écart est rattaché à sa source et étiqueté comme fait ou comme déclaration.

Type	Référentiel	Application	Écarts	Justification
Bonnes pratiques	Guide d'hygiène informatique de l'ANSSI	Partiel	Absence d'authentification multifacteur (MFA) sur les accès distants. Sauvegardes non vérifiées en restauration et non déconnectées.	[Fait] Constat du diagnostic MEHARI (MFA partiel, sauvegardes locales non testées).
Réglementation	RGPD	Partiel	Habilitations trop larges. Erreurs de manipulation récurrentes (mauvais partages, erreurs de mails).	[Déclaration] Remontée lors de l'analyse MEHARI (données des apprenants mal cloisonnées).
Contrat	Contrat d'infogérance et plan d'assurance sécurité	Faible, non formalisé	L'infogérant (PP1) a des accès administrateurs permanents sans contrôle. Pas de plan de reprise externalisé testé.	[Fait / Déclaration] Constat MEHARI : forte dépendance aux services externes, pas de plan de continuité formalisé.
Politique interne	PSSI (charte informatique, politique de télétravail)	Inexistant	Appareils personnels utilisés sans cadre de sécurité. Sensibilisation insuffisante à l'hameçonnage.	[Fait] Incidents remontés dans MEHARI (hameçonnage récurrent, travail nomade).

Ces écarts alimentent directement le plan de traitement : le MFA (M9), les sauvegardes déconnectées (M6), la revue des accès de l'infogérant (M2, M3) et la sensibilisation (M4).

3. Atelier 2 – Sources de risque

Rédaction : Chloé

Cet atelier identifie **qui pourrait chercher à nuire à la PME, et dans quel but**. Nous avons retenu cinq couples source de risque / objectif visé. Ils couvrent trois types de menace : la cybercriminalité lucrative, la menace interne et la malveillance opportuniste.

3.1 Méthode

Nous avons parcouru les profils d'attaquants et les objectifs visés proposés par la fiche méthode de l'atelier 2 de l'ANSSI. Pour chaque source de risque plausible, nous avons formulé un objectif précis, relié à une valeur métier de la PME, plutôt qu'une finalité générique.

Chaque couple est coté sur sa motivation (l'intérêt de la source à viser notre PME) et sur ses ressources (moyens financiers, outils, compétences et accès). La pertinence se déduit de la grille de l'onglet Métriques. Cette grille compte trois niveaux, contre quatre dans la fiche méthode : nous avons conservé celle du classeur officiel pour rester cohérents avec ses calculs.

3.2 Couples évalués

Code	Source de risque	Objectif visé	Motiv.	Ress.	Pertinence	Retenu (prio.)
SROV1	Organisation criminelle	Chiffrer l'ERP et le CRM et voler les données pour exiger une rançon	++	+++	Élevée	Oui (1)
SROV2	Organisation criminelle	Détourner des paiements par fraude au changement de coordonnées bancaires	+++	++	Élevée	Oui (1)
SROV3	Concurrent	Obtenir le fichier clients et apprenants et les tarifs pour capter la clientèle	++	++	Moyenne	Oui (2)
SROV4	Salarié ou ex-salarié malveillant	Extraire ou altérer les données commerciales avant ou après son départ	+++	+	Moyenne	Oui (1)
SROV5	Amateur ou hacktiviste	Rendre la plateforme indisponible par défi ou recherche de visibilité	++	++	Moyenne	Oui (2)
SROV6	Activiste	Nuire à l'image de la PME en divulguant des données	+	+	Faible	Non
SROV7	Organisation étatique	Espionnage	+	+++	Moyenne	Non

3.3 Justification des couples retenus

SROV1 – Organisation criminelle, rançon (pertinence élevée, priorité 1). Les TPE, PME et ETI représentent 48 % des victimes de rançongiciels traitées par l'ANSSI en 2025 [1]. Ces attaques sont principalement opportunistes : notre PME n'est pas visée pour elle-même, mais parce qu'elle est exposée. Nous cotons donc la motivation à ++ plutôt qu'à +++. Les ressources sont maximales (+++) : ces groupes utilisent des rançongiciels proposés comme un service, prêts à l'emploi. L'ANSSI relève aussi des exfiltrations de données consécutives à la compromission d'un prestataire [1], ce qui rend crédible un passage par notre infogérant.

SROV2 – Organisation criminelle, fraude au faux RIB (pertinence élevée, priorité 1). La fraude au virement est la troisième cybermalveillance signalée par les professionnels en 2025, en hausse de 93 % [2]. Elle s'appuie sur le piratage de compte et l'hameçonnage, les deux premières menaces du

classement [2]. La motivation est maximale (+++) : le gain est direct, et le processus de facturation de la PME manipule des coordonnées bancaires dans l'ERP. Les ressources sont significatives (++) : le mode opératoire demande peu de technique.

SROV3 – Concurrent, vol du fichier clients (pertinence moyenne, priorité 2). Le fichier clients et apprenants et la grille tarifaire ont une valeur commerciale directe pour un concurrent. Un concurrent de PME dispose rarement de capacités offensives, mais la fiche méthode de l'ANSSI rappelle qu'il peut faire appel à une officine spécialisée. Nous cotons donc ses ressources à ++. Son point d'entrée le plus crédible est un formateur indépendant qui travaille aussi pour d'autres organismes (voir SS3).

SROV4 – Salarié ou ex-salarié malveillant (pertinence moyenne, priorité 1). La motivation peut être forte (+++) lors d'un départ, d'un conflit ou d'une embauche chez un concurrent. Les moyens techniques sont faibles (+), mais cette source dispose d'accès légitimes au CRM et connaît les processus internes. Nous lui donnons la priorité 1 malgré une pertinence moyenne : elle n'a besoin d'aucune intrusion, ce qui rend le scénario difficile à détecter.

SROV5 – Amateur ou hacktiviste, indisponibilité (pertinence moyenne, priorité 2). La motivation relève du défi ou de la recherche de visibilité (++). Les ressources sont significatives (++) : des services de déni de service se louent à bas coût et des outils d'attaque sont disponibles en ligne. Ce couple est retenu en priorité 2 car il vise la disponibilité de la plateforme, en particulier la planification des sessions (VM4).

3.4 Justification des couples exclus

- **SROV6 – Activiste :** aucune cause militante n'est liée à l'activité de formation de la PME. Motivation et ressources faibles.
- **SROV7 – Organisation étatique :** la grille donne une pertinence moyenne, du fait de ressources maximales. Nous l'excluons pourtant : la PME ne détient aucune information d'intérêt stratégique, et la motivation d'un État à la viser est quasi nulle. C'est un choix d'analyse, assumé contre la lecture mécanique de la grille.

3.5 Ce que l'atelier 2 transmet à la suite

Chaque couple retenu donne un scénario stratégique à l'atelier 3. Les couples exclus (SROV6 et SROV7) n'en donnent pas. Les prestataires ne sont pas des sources de risque : ils sont étudiés à l'atelier 3 comme parties prenantes par lesquelles une attaque peut passer.

Couple	Scénario	Point de passage	Événements redoutés visés
SROV1	SS1	Prestataire d'infogérance (PP1)	ER1, ER7 (indisponibilité CRM et ERP), ER6 (divulgation massive)
SROV2	SS2	Attaque directe par hameçonnage	ER8 (altération des coordonnées bancaires)
SROV3	SS3	Formateur indépendant (PP7)	ER3 (divulgation de données clients)
SROV4	SS4	Compte non désactivé, annuaire géré par PP1	ER2, ER3 (altération et divulgation CRM)
SROV5	SS5	Éditeur ERP/CRM (PP3) ou hébergeur (PP2)	ER10, ER1 (indisponibilité planification et CRM)

4. Atelier 3 – Écosystème et scénarios stratégiques

Parties prenantes : Camille

Neuf parties prenantes ont été évaluées. L'indice de menace vaut (dépendance × pénétration) / (maturité × confiance) : plus il est élevé, plus la partie prenante expose la PME.

Catégorie	Partie prenante	Dép.	Pén.	Mat.	Conf.	Expo.	SSI	Indice
Prestataire technique	PP1 Infogérant	3	4	2	2	12	4	3,0
Hébergeur cloud	PP2 Hébergeur (IaaS)	4	3	4	3	12	12	1,0
Éditeur logiciel	PP3 Éditeur ERP/CRM	4	2	2	2	8	4	2,0
Fournisseur cloud	PP4 Messagerie	3	1	4	3	3	12	0,25
Prestataire financier	PP5 Paiement	3	1	4	3	3	12	0,25
Partenaire métier	PP6 Expert-comptable	2	2	2	3	4	6	0,67
Intervenants externes	PP7 Formateurs indépendants	4	3	1	2	12	2	6,0
Clients et financeurs	PP8 Clients / OPCO	4	1	2	3	4	6	0,67
Opérateur télécom	PP9 FAI	4	1	3	3	4	9	0,44



Figure 1 – Cartographie de dangerosité des parties prenantes

Quatre parties prenantes sont **critiques** et doivent figurer dans les scénarios stratégiques : PP7 et PP1 en zone de danger, PP3 et PP2 en zone de contrôle. Les seuils de danger (3) et de contrôle (0,9) sont ceux du classeur ; le seuil de veille (0,3) est un choix du groupe (hypothèse H8).

Scénarios stratégiques et mesures écosystème : Nathan

4.2 Scénarios stratégiques

Cinq scénarios stratégiques, un par couple retenu. Chacun relie une source de risque, un point de passage, les valeurs métier visées et les événements redoutés.

Code	Source de risque	Point de passage	Valeurs métier	ER	Grav.	Schéma
SS1	Organisation criminelle	PP1 — Infogérant	VM1 — Gestion commerciale ; VM3 — Facturation	ER1, ER7, ER6	G4	onglet SS1
SS2	Organisation criminelle	Attaque directe via messagerie (BS8) ; aucun prestataire intermédiaire	VM3 — Facturation et encaissement	ER8	G4	onglet SS1
SS3	Concurrent	PP7 — Formateurs indépendants	VM2 — Fichier clients et apprenants	ER3	G3	onglet SS1

Code	Source de risque	Point de passage	Valeurs métier	ER	Grav.	Schéma
SS4	Salarié ou ex-salarié malveillant	PP1 — Infogérant (annuaire et comptes)	VM1 — Gestion commerciale ; VM2 — Fichier clients	ER2, ER3	G3	onglet SS1
SS5	Amateur ou hacktiviste	PP3 — Éditeur ERP/CRM ou PP2 — Hébergeur cloud	VM4 — Planification ; VM1 — Relation client	ER10, ER1	G3	onglet SS1

Justification des gravités

- **SS1 (G4) :** l'arrêt simultané du CRM et de l'ERP, combiné à une fuite massive de données, menace la continuité commerciale et financière et peut engager durablement la confiance et la conformité.
- **SS2 (G4) :** une modification frauduleuse des coordonnées bancaires ou des montants peut provoquer un détournement de fonds significatif et des litiges difficiles à réparer.
- **SS3 (G3) :** la divulgation du fichier clients peut entraîner perte de clientèle et atteinte à la réputation, mais n'interrompt pas directement toute l'activité.
- **SS4 (G3) :** l'exfiltration ou l'altération des données commerciales est importante et peut affecter les contrats, mais reste circonscrite aux données concernées et peut être détectée/réparée.
- **SS5 (G3) :** l'indisponibilité perturbe fortement les sessions et le suivi commercial, mais des modes dégradés et des sauvegardes peuvent limiter la durée de l'impact.

Les schémas des cinq scénarios figurent dans l'onglet « Atelier 3 - SS1 » du classeur (annexe B).

4.3 Mesures sur l'écosystème

Pour chaque partie prenante critique, des mesures de réduction, surtout contractuelles, avec l'indice de menace visé après mesure.

Partie prenante	Mesures	Indice visé
PP1 - Prestataire d'infogérance	Comptes nominatifs et MFA ; moindre privilège ; journalisation des actions d'administration ; revue trimestrielle des comptes ; désactivation des accès sous 24 h après départ.	2
PP2 - Hébergeur Cloud (IaaS)	SLA de disponibilité et notification d'incident ; redondance et sauvegardes ; contrôle des accès administrateurs ; protection anti-DDoS ; clauses de réversibilité et tests de restauration.	1
PP3 - Éditeur de l'ERP/CRM	SLA de correction des vulnérabilités critiques ; notification des failles ; comptes administrateurs nominatifs ; journaux d'administration ; engagements de sécurité inscrits au contrat.	1
PP7 - Formateurs indépendants	Comptes nominatifs et MFA si disponible ; charte de confidentialité ; sensibilisation ; accès limité au strict nécessaire ; révocation des accès en fin de mission ; règles BYOD.	3

Rappel : on ne peut pas imposer de mesure technique à une partie prenante comme à un bien support ; ces mesures passent par le contrat et la sensibilisation (hypothèse de responsabilité EBIOS).

5. Atelier 4 – Scénarios opérationnels

Rédaction : Camille

Chaque scénario stratégique est décliné en un scénario opérationnel, représenté par un graphe d'attaque en quatre phases : connaître, rentrer, trouver, exploiter. Chaque action élémentaire est rattachée au bien support visé et à une technique du référentiel MITRE ATT&CK. La vraisemblance est cotée en méthode expresse, directement sur le scénario.

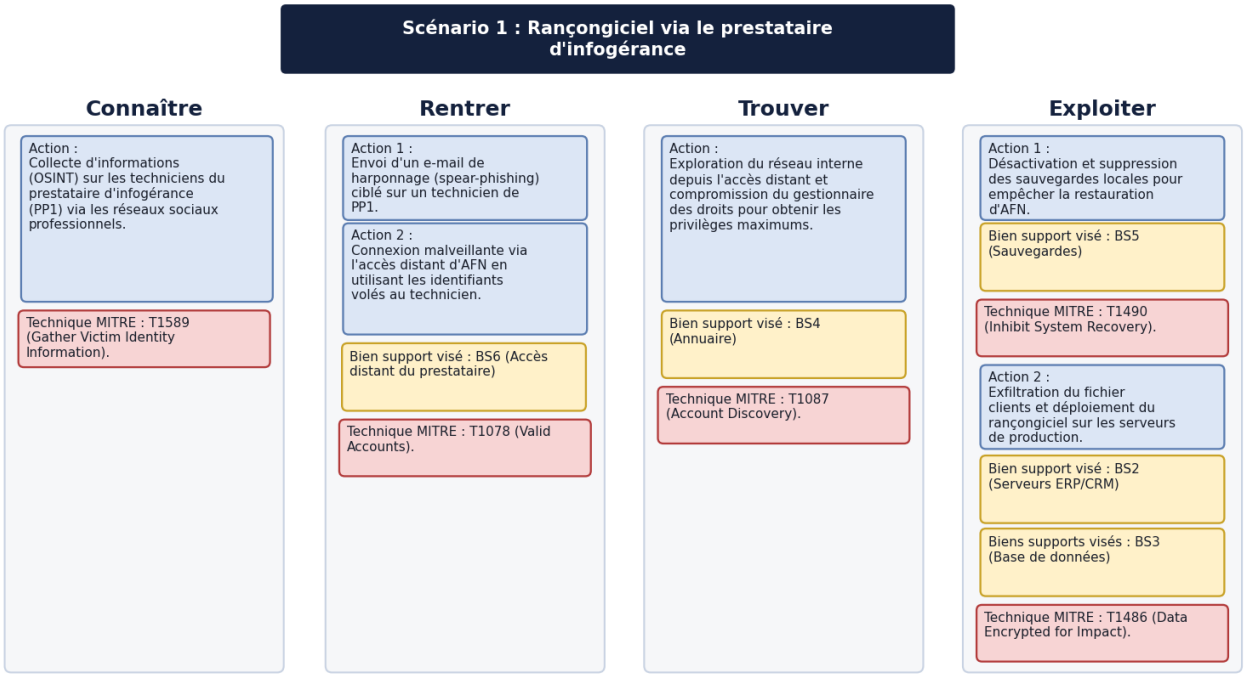


Figure 2 – SO1 : rançongiciel via le prestataire d'infogérance

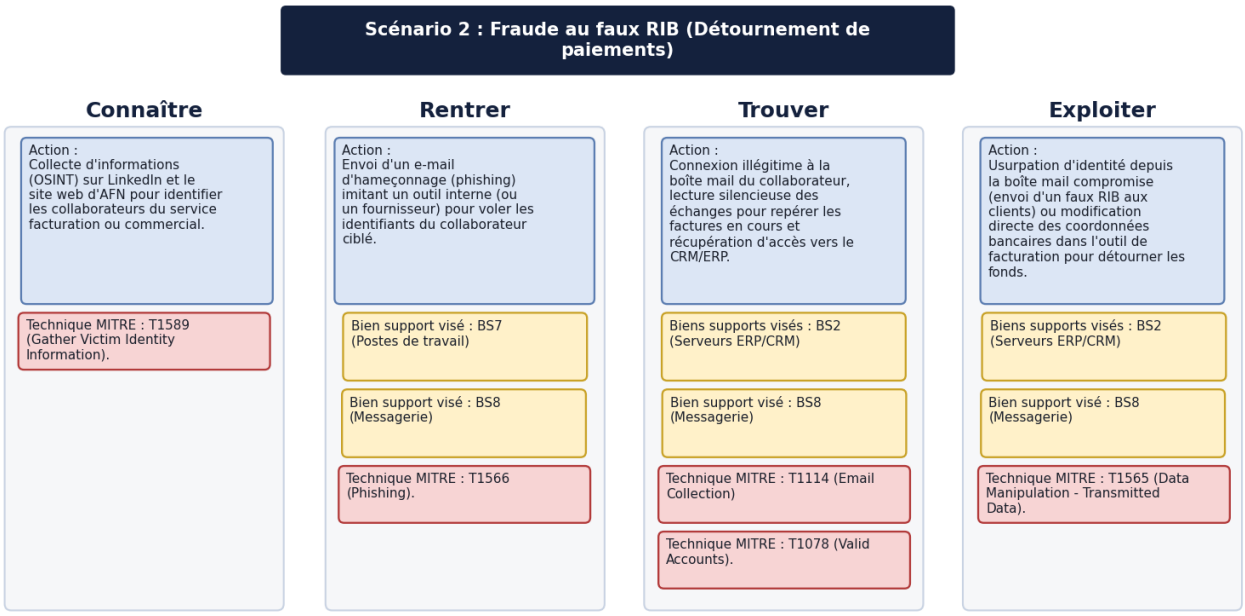


Figure 3 – SO2 : fraude au faux RIB

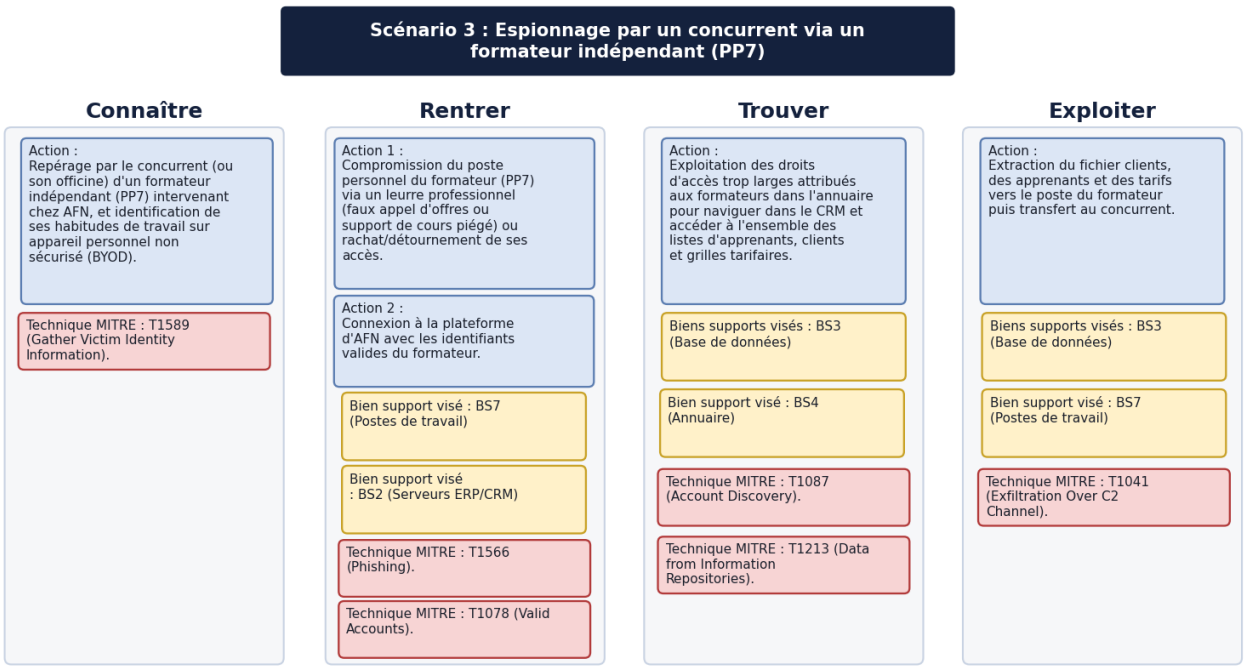


Figure 4 – SO3 : vol du fichier clients via un formateur indépendant

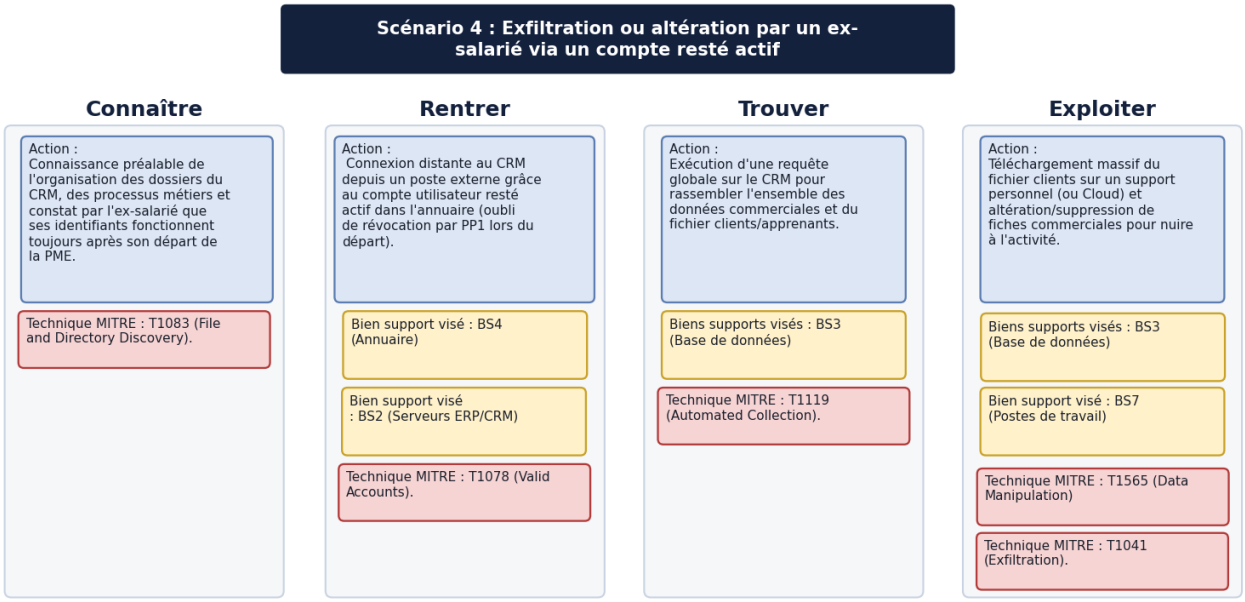


Figure 5 – SO4 : fuite de données par un ex-salarié via un compte non désactivé

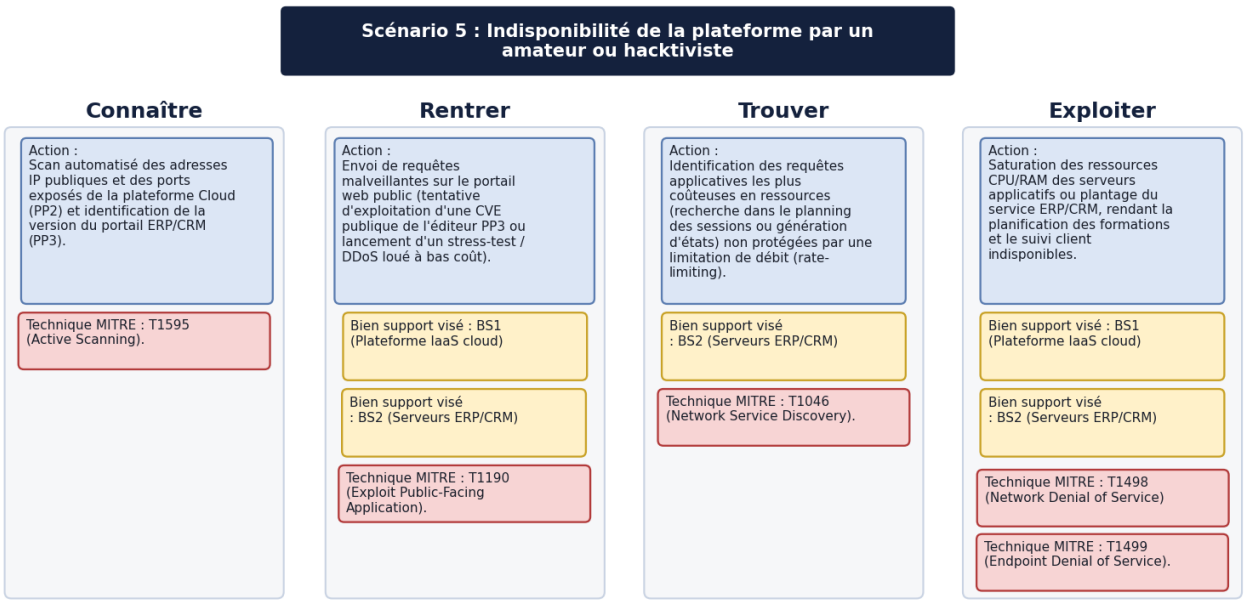


Figure 6 – SO5 : indisponibilité de la plateforme par un amateur

SO	Vrais.	Justification	Après	Mesures qui la font baisser
SO1	V4	L'accès administrateur distant de l'infogérant n'est pas protégé par MFA ; sans cloisonnement, l'attaquant atteint l'annuaire et détruit les sauvegardes locales.	V2	MFA (M9), supervision (M13)
SO2	V4	L'hameçonnage est déjà constaté et la messagerie n'a pas de MFA : des identifiants volés suffisent.	V1	MFA (M9), contre-appel avant changement de RIB (M10)
SO3	V3	Le formateur indépendant utilise son propre matériel, sans antivirus imposé ni MFA, et a des droits trop larges dans l'annuaire.	V1	MFA (M9), droits des formateurs limités (M14), supervision (M13)
SO4	V4	Pas de procédure de départ avec l'infogérant : des comptes restent actifs, et rien ne bloque les exports massifs.	V2	Revue des accès (M3), blocage des exports (M11), supervision (M13)
SO5	V3	Les outils de saturation se louent facilement ; pas de pare-feu applicatif, et les correctifs de l'éditeur sont appliqués tard.	V1	Pare-feu applicatif et correctifs (M12)

Les cinq graphes d'attaque ci-dessus sont tirés du fichier draw.io du groupe ; les techniques MITRE ATT&CK y figurent à chaque étape.

6. Atelier 5 – Traitement du risque

Rédaction : Chloé

Cette partie rassemble les cinq risques issus des scénarios, fixe les règles de traitement et construit le plan d'action. Les vraisemblances viendront des scénarios opérationnels (partie 5) : tant qu'elles ne sont pas validées, le niveau de risque reste en attente.

6.1 Calcul du niveau de risque

Le niveau de risque croise la gravité du scénario stratégique et la vraisemblance du scénario opérationnel, selon la matrice de l'onglet Métriques du classeur :

Gravité / Vraisemblance	V1	V2	V3	V4
G4	3 Modéré	3 Modéré	4 Élevé	4 Élevé
G3	2 Significatif	3 Modéré	3 Modéré	4 Élevé
G2	2 Significatif	2 Significatif	3 Modéré	3 Modéré
G1	1 Faible	1 Faible	2 Significatif	2 Significatif

L'onglet Atelier 5 du classeur propose trois niveaux (faible, moyen, élevé), alors que l'onglet Métriques en définit quatre. Nous retenons les quatre niveaux de l'onglet Métriques, plus précis pour prioriser (hypothèse H9).

6.2 Synthèse des risques

N°	Intitulé	Couple	ER	SS	Grav.	Vrais.	Niveau
R1	Une organisation criminelle paralyse la facturation et la relation client en chiffrant l'ERP et le CRM via le prestataire d'infogérance	SROV1	ER1, ER6, ER7	SS1	G4	V4	4 Élevé
R2	Une organisation criminelle détourne des paiements en modifiant les coordonnées bancaires après hameçonnage	SROV2	ER8	SS2	G4	V4	4 Élevé
R3	Un concurrent récupère le fichier clients et apprenants par l'intermédiaire d'un formateur indépendant	SROV3	ER3	SS3	G3	V3	3 Modéré
R4	Un ex-salarié exfiltre ou altère les données du CRM grâce à un compte non désactivé	SROV4	ER2, ER3	SS4	G3	V4	4 Élevé
R5	Un amateur rend la plateforme indisponible en exploitant une vulnérabilité ou en saturant les services exposés	SROV5	ER1, ER10	SS5	G3	V3	3 Modéré

Trois risques sont **élevés** : le rançongiciel via l'infogérant (R1), la fraude au faux RIB (R2) et la fuite par un ex-salarié (R4). R3 (concurrent via un formateur) et R5 (amateur) sont modérés.

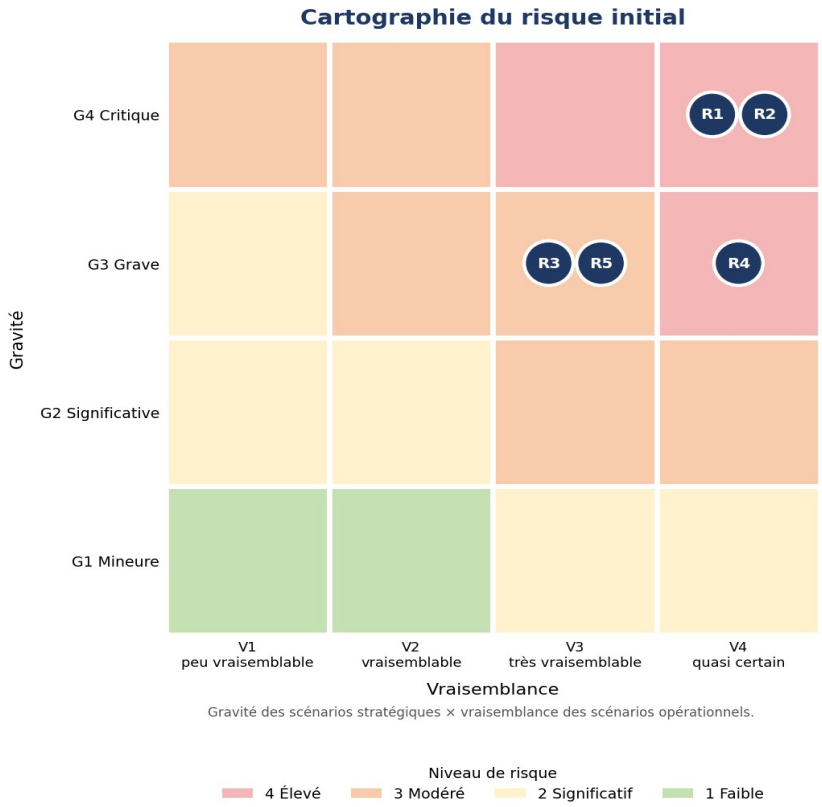


Figure 7 – Cartographie du risque initial

6.3 Règles de traitement

Nous proposons des règles de décision fixées avant de connaître les niveaux, pour que le choix ne dépende pas du résultat :

Niveau initial	Décision	Justification
Élevé (4)	Réduire, en priorité	Risque inacceptable en l'état : mesures planifiées à court terme et suivies en comité.
Modéré (3)	Réduire	Risque à ramener au niveau significatif au plus tard dans l'année.
Significatif (2)	Réduire ou accepter	Accepté si les mesures coûtent plus que l'impact évité. L'acceptation est signée par la direction.
Faible (1)	Accepter	Simple suivi lors de la revue annuelle.

En application de ces règles, les quatre risques cotés (R1 à R4) sont à réduire, R1, R2 et R4 en priorité.

Le transfert, par une assurance cyber, peut compléter la réduction pour R1 et R2, dont l'impact financier est le plus fort. Il ne la remplace pas : un assureur exige en général des mesures de base, comme l'authentification multifacteur et des sauvegardes déconnectées.

6.4 Plan de traitement du risque

Le plan regroupe les mesures selon les quatre groupes de la sécurité en profondeur. Chaque mesure a un propriétaire, une échéance et un indicateur. Les propriétaires sont des fonctions de la PME : le cas étant fictif, aucune personne nommée.

N°	Mesure	Risques	Propriétaire	Échéance	Indicateur
M1	Formaliser les responsabilités	Tous	Direction	M+1	100 % des

N°	Mesure	Risques	Propriétaire	Échéance	Indicateur
	SSI, y compris vis-à-vis de l'hébergeur et de l'infogérant				responsabilités critiques documentées
M2	Ajouter des exigences de sécurité au contrat d'infogérance : MFA, comptes nominatifs, moindre privilège, journalisation, notification d'incident, droit d'audit	R1, R4	Direction	M+3	Avenant signé
M3	Revoir chaque trimestre les accès des prestataires et supprimer les accès non justifiés	R1, R4	Responsable administratif	M+3, puis tous les 3 mois	100 % des comptes prestataires revus
M4	Sensibiliser le personnel à l'hameçonnage, à la fraude au changement de RIB et à la protection des données	R1, R2	Responsable administratif	M+3, puis chaque année	Au moins 95 % du personnel formé
M5	Ajouter une clause de gestion des incidents dans les contrats des fournisseurs critiques	R1, R5	Direction	M+3	Clause présente chez 100 % des fournisseurs critiques

Groupe gouvernance, mesures proposées par Nathan.

N°	Mesure	Risques	Propriétaire	Échéance	Indicateur
M6	Sauvegardes de l'ERP et du CRM déconnectées ou non modifiables, avec un test de restauration chaque trimestre	R1, R5	Infogérant, contrôlé par le responsable administratif	M+2	Test de restauration réussi chaque trimestre
M7	Procédure de fonctionnement en mode dégradé : facturation et planning sans ERP ni CRM pendant 5 jours	R1, R5	Responsable administratif et financier	M+4	Procédure testée une fois par an
M8	Procédure de gestion de crise cyber : contacts d'urgence, décision de couper les accès, notification à la CNIL sous 72 h en cas de fuite de données personnelles	R1, R3, R4	Direction	M+3	Exercice de crise réalisé une fois par an

Groupe résilience, mesures proposées par Chloé.

N°	Mesure	Risques	Propriétaire	Échéance	Indicateur
M9	Authentification multifacteur sur tous les accès distants (VPN) et cloud (messagerie, ERP/CRM)	R1, R2	Infogérant, piloté par la direction	M+2	100 % des accès distants et cloud protégés par MFA
M10	Contre-appel systématique au numéro historique avant toute modification de RIB dans l'ERP	R2	Responsable administratif et financier	M+1	100 % des changements de RIB validés par contre-appel tracé
M11	Restriction des exports massifs dans le CRM et blocage des supports USB non autorisés	R4	Infogérant	M+2	Aucun export de base sans validation hiérarchique
M12	Pare-feu applicatif web devant le portail ERP/CRM et application stricte des correctifs	R5	Infogérant	M+3	100 % des vulnérabilités critiques corrigées sous 7 jours
M14	Limiter les droits des formateurs	R3	Infogérant	M+2	100 % des comptes

N°	Mesure	Risques	Propriétaire	Échéance	Indicateur
	indépendants au strict nécessaire dans le CRM et l'annuaire (moindre privilège)				formateurs revus
M13	Supervision des journaux d'accès (serveurs, VPN, ERP) avec alertes sur connexions hors horaires, requêtes suspectes et exports massifs	R1, R3, R4	Infogérant (service de supervision)	M+6	100 % des alertes critiques traitées en moins de 2 heures

Groupes protection (M9 à M12) et défense (M13), mesures proposées par Camille.

6.4 bis Priorisation du plan

Les mesures sont classées en trois vagues. La **première vague** regroupe les mesures qui cassent l'étape « Rentrer » des scénarios les plus graves, ou qui sont rapides et peu coûteuses. Le MFA (M9) arrive en tête : il bloque à lui seul l'entrée de R1 et de R2, les deux risques en G4.

Vague	N°	Mesure	Groupe	Risques	Échéance	Complexité
1	M9	MFA sur les accès distants et cloud	Protection	R1, R2	M+2	Moyenne
1	M10	Contre-appel avant changement de RIB	Protection	R2	M+1	Faible
1	M6	Sauvegardes déconnectées testées	Résilience	R1, R5	M+2	Moyenne
1	M3	Revue trimestrielle des accès prestataires	Gouvernance	R1, R4	M+3	Faible
1	M1	Responsabilités SSI formalisées	Gouvernance	Tous	M+1	Faible
1	M14	Droits des formateurs limités au nécessaire	Protection	R3	M+2	Faible
2	M2	Avenant sécurité au contrat d'infogérance	Gouvernance	R1, R4	M+3	Moyenne
2	M11	Blocage des exports massifs et des clés USB	Protection	R4	M+2	Moyenne
2	M4	Sensibilisation hameçonnage et faux RIB	Gouvernance	R1, R2	M+3	Faible
2	M8	Procédure de gestion de crise cyber	Résilience	R1, R3, R4	M+3	Moyenne
2	M13	Supervision des journaux et alertes	Défense	R1, R3, R4	M+6	Forte
3	M7	Fonctionnement en mode dégradé	Résilience	R1, R5	M+4	Moyenne
3	M5	Clause incidents chez les fournisseurs critiques	Gouvernance	R1, R5	M+3	Faible
3	M12	Pare-feu applicatif et correctifs	Protection	R3	M+3	Moyenne

Ordre de grandeur de coût (indicatif). Vague 1 : faible, surtout de la configuration et des procédures internes (le MFA est inclus dans les licences existantes). Vague 2 : modéré, l'essentiel porté par l'avenant d'infogérance et la supervision des journaux (M13), seule mesure récurrente notable. Vague 3 : faible à modéré. À préciser avec les devis du prestataire.

6.5 Risque résiduel et suivi

Le groupe a choisi de ne réévaluer que la vraisemblance après mesures, et de garder les gravités initiales (hypothèse H11) : les mesures retenues empêchent surtout l'attaque d'aboutir, sans réduire de façon démontrable l'impact d'une attaque réussie.

Risque	Niveau initial	Mesures principales	Vrais. après	Niveau résiduel	Décision
R1	4 Élevé (G4, V4)	M9, M13, M6, M2, M3	V2	3 Modéré (G4, V2)	Accepté par la direction, revu chaque trimestre
R2	4 Élevé (G4, V4)	M9, M10, M4	V1	3 Modéré (G4, V1)	Accepté par la direction, revu chaque trimestre
R3	3 Modéré (G3, V3)	M9, M14, M13	V1	2 Significatif (G3, V1)	Accepté par la direction
R4	4 Élevé (G3, V4)	M11, M13, M3	V2	3 Modéré (G3, V2)	Accepté par la direction, revu chaque trimestre
R5	3 Modéré (G3, V3)	M12	V1	2 Significatif (G3, V1)	Accepté par la direction

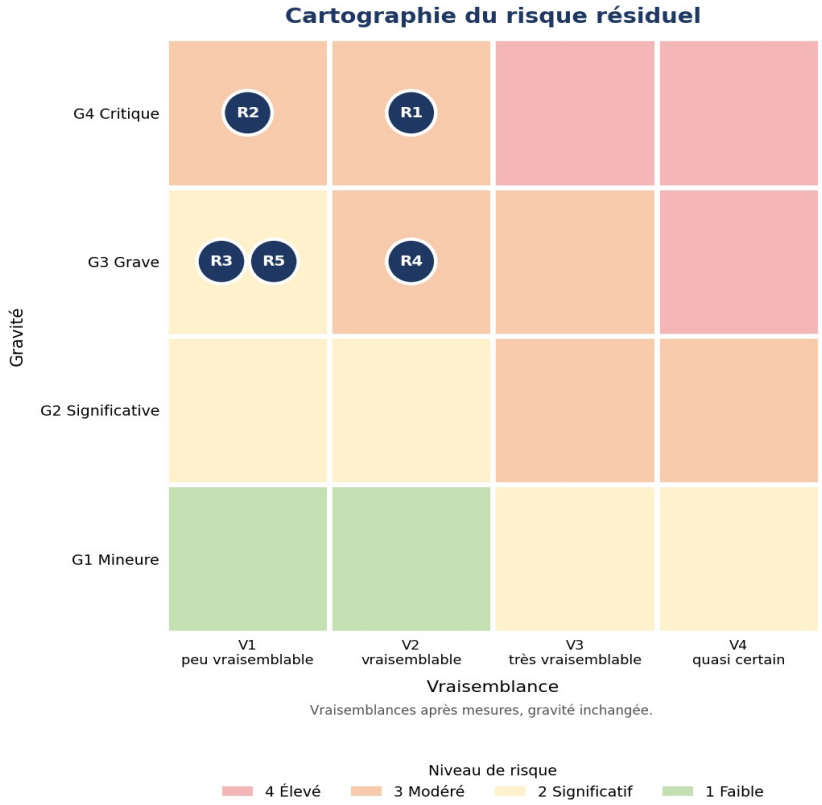


Figure 8 – Cartographie du risque résiduel

Aucun risque ne reste élevé après mesures. R3 et R5 descendent au niveau significatif. En revanche, **R1, R2 et R4 restent modérés** : leur gravité (G4 pour R1 et R2) fait que, même avec une vraisemblance minimale, la matrice du classeur ne descend pas sous « modéré ». Ces trois risques restent au-dessus de l'objectif fixé en 6.3.

Leur maintien à ce niveau est une **décision explicite de la direction**, prise en connaissance de cause et réexaminée à chaque revue trimestrielle. Pour R1 et R2, une assurance cyber peut couvrir une partie de l'impact financier résiduel.

Le suivi des risques est organisé ainsi :

- **Revue trimestrielle** par la direction et le responsable administratif : avancement du plan, indicateurs des mesures, incidents survenus.
- **Revue annuelle** du cycle opérationnel (ateliers 4 et 5) : mise à jour des vraisemblances et du plan.

– **Revue anticipée** en cas d’incident majeur, de changement de prestataire ou de nouvelle application dans le périmètre.

7. Conclusion pour la direction

Rédaction : Chloé, relue par le groupe

La plateforme qui porte la facturation et la relation client est aujourd'hui exposée à trois risques élevés. Quatorze mesures, dont six à lancer dans les trois premiers mois, les ramènent à un niveau modéré en six mois.

Les risques majeurs

1. **Rançongiciel via le prestataire d'infogérance (R1).** Il bloquerait la facturation et le suivi des clients, avec une fuite possible des données des clients et apprenants. La porte d'entrée existe déjà : l'accès à distance du prestataire n'est protégé que par un mot de passe.

2. **Fraude au faux RIB (R2).** Un escroc qui prend le contrôle d'une boîte mail peut faire modifier des coordonnées bancaires et détourner des paiements. Aucune vérification n'est prévue avant un tel changement.

3. **Fuite du fichier clients par un salarié sur le départ (R4).** Rien ne détecte aujourd'hui un export massif du fichier clients, ni l'usage d'un compte resté actif après un départ.

Deux risques modérés complètent le tableau : le vol du fichier clients par un concurrent via un formateur indépendant (R3) et la mise hors service de la plateforme par un amateur (R5).

Les actions prioritaires, dans les trois premiers mois

- Activer la double authentification sur tous les accès à distance et les outils en ligne (M9) : cette seule mesure bloque l'entrée des deux risques les plus graves.
- Vérifier par téléphone toute demande de changement de RIB (M10).
- Mettre en place des sauvegardes déconnectées, testées chaque trimestre (M6).
- Revoir chaque trimestre les accès du prestataire et des formateurs (M3, M14).
- Désigner clairement les responsables de la sécurité, en interne et chez les prestataires (M1).

Ces premières mesures relèvent surtout de la configuration et de procédures internes : leur coût est faible. La mesure la plus lourde, la supervision des accès (M13), arrive en seconde vague.

Les décisions attendues de la direction

1. **Valider le plan en trois vagues** et désigner son pilote, avec un point d'avancement chaque trimestre.

2. **Négocier un avenant de sécurité avec le prestataire d'infogérance** (M2) : il met en œuvre une grande partie des mesures, sans quoi le plan ne peut pas s'appliquer.

3. **Accepter formellement le risque restant.** Même après le plan, R1, R2 et R4 restent modérés, car leurs conséquences restent graves. La direction peut accepter ce niveau ou aller plus loin, par exemple avec une assurance cyber pour R1 et R2.

Limites. Cette analyse porte sur un cas fictif, sans audit technique sur place. Les cotations reposent sur le jugement du groupe et sur des sources publiques citées.

Sources

[1] ANSSI – CERT-FR, Panorama de la cybermenace 2025, CERTFR-2026-CTI-002, 2026. https://www.cert.ssi.gouv.fr/uploads/CERTFR-2026-CTI-002.pdf

[2] Cybermalveillance.gouv.fr, Quelles sont les principales cybermalveillances visant les professionnels en 2025 ?, mai 2026. https://www.cybermalveillance.gouv.fr/tous-nos-contenus/actualites/top10-cybermalveillances-professionnels-2025

[3] ANSSI, Guide EBIOS Risk Manager, version 1.5, et fiches méthode des ateliers 1 à 5.

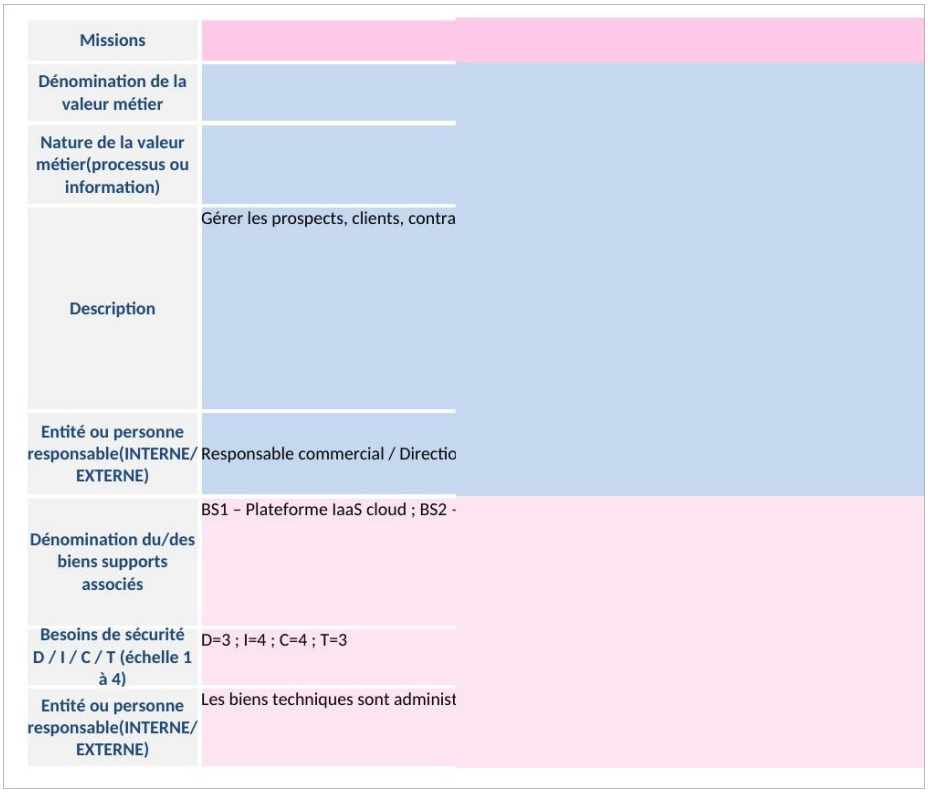
Annexe A – Journal d’hypothèses

N°	Atelier	Statut	Hypothèse ou information	Auteur
H1	1	Hypothèse	Une indisponibilité de plus d’une journée des activités commerciales et administratives entraîne une forte perturbation.	Nathan
H2	1	Hypothèse	Le fichier clients et apprenants contient des données personnelles ; volumes non fournis.	Nathan
H3	1	Hypothèse	Une altération des coordonnées bancaires ou des montants peut provoquer une fraude ou des erreurs financières importantes.	Nathan
H4	3	Hypothèse	PP1 prestataire d’infogérance, PP2 hébergeur cloud, PP3 éditeur ERP/CRM (codes de l’onglet Atelier 3 - PP).	Nathan, corrigée par Chloé
H5	2	Fait sourcé	Les TPE, PME et ETI représentent 48 % des victimes de rançongiciels traitées par l’ANSSI en 2025 [1].	Chloé
H6	2	Fait sourcé	La fraude au virement est la 3e cybermalveillance signalée par les professionnels en 2025 [2].	Chloé
H7	2	Hypothèse	Les commerciaux disposent d’un accès au CRM permettant d’en extraire le fichier clients.	Chloé
H8	3	Choix d’analyse	Seuil de veille fixé à 0,3 (le classeur indique 0) pour appliquer la règle des 10 % hors périmètre de la fiche méthode.	Chloé
H9	5	Choix d’analyse	Niveau de risque en quatre niveaux (onglet Métriques) plutôt qu’en trois (onglet Atelier 5).	Chloé
H10	5	Hypothèse	La PME peut facturer et planifier sans ERP ni CRM pendant environ 5 jours en mode dégradé.	Chloé
H11	5	Choix d’analyse	Gravités inchangées après mesures : seule la vraisemblance est réévaluée pour le risque résiduel.	Groupe

Annexe B – Captures du classeur

Captures des onglets du classeur EBIOS_RM_Groupe_MAITRE_v9. Le radar des parties prenantes figure en figure 1 (partie 4) et les graphes d'attaque en figures 2 à 6 (partie 5).

Atelier 1 – Missions (valeurs métier et biens supports)



Missions	
Dénomination de la valeur métier	
Nature de la valeur métier(processus ou information)	
Description	Gérer les prospects, clients, contra
Entité ou personne responsable(INTERNE/ EXTERNE)	Responsable commercial / Directio
Dénomination du/des biens supports associés	BS1 – Plateforme IaaS cloud ; BS2 -
Besoins de sécurité D / I / C / T (échelle 1 à 4)	D=3 ; I=4 ; C=4 ; T=3
Entité ou personne responsable(INTERNE/ EXTERNE)	Les biens techniques sont administ

Atelier 1 – Événements redoutés

Valeur métier	Evenement redouté
VM1 – Gestion commerciale et relation client	ER1 – Indisponibilité du CRM et des données commerciales pendant plusieurs jours, empêchant le suivi des prospects, clients et contrats.
VM1 – Gestion commerciale et relation client	ER2 – Altération des informations clients, contrats ou opportunités dans le CRM.
VM1 – Gestion commerciale et relation client	ER3 – Divulgation non autorisée de données clients et d'informations commerciales.
VM2 – Fichier clients et apprenants	ER4 – Indisponibilité du fichier clients et apprenants pendant plus d'une journée.
VM2 – Fichier clients et apprenants	ER5 – Altération ou suppression de données d'identification et de suivi des apprenants.
VM2 – Fichier clients et apprenants	ER6 – Divulgation massive de données personnelles de clients et d'apprenants.
VM3 – Facturation et encaissement	ER7 – Indisponibilité de l'ERP de facturation et des données d'encaissement.
VM3 – Facturation et encaissement	ER8 – Altération des montants, coordonnées bancaires ou statuts de règlement.
VM3 – Facturation et encaissement	ER9 – Divulgation de données financières et comptables.

Atelier 1 – Socle de sécurité (GAP)

Identification		C
Type de référentiel	**Nom du referentiel**	**Etat d'application**
Bonnes pratiques	Guide d'hygiène informatique de l'ANSSI	Partiel
Réglementation	RGPD (Règlement Général sur la Protection des Données)	Partiel
Contrat	Contrat d'infogérance et PAS (Plan	Faible / Non formalisé
Politique interne	PSSI (Charte informatique et Politiq	Inexistant

Atelier 2 – Sources de risque (SROV)

Identification	
Sources de risque	**Objectifs visés**
SROV1 – Organisation criminelle (SR1)	Chiffrer l'ERP et le CRM et voler les données pour exiger une rançon (double extorsion)
SROV2 – Organisation criminelle (SR2)	Détourner des paiements par fraude au changement de coordonnées bancaires (faux RIB) via la messagerie et l'ERP
SROV3 – Concurrent (SR3)	Obtenir le fichier clients et apprenants et les tarifs pour capter la clientèle
SROV4 – Salarié ou ex-salarié malveillant (SR4)	Extraire ou altérer les données commerciales et le fichier clients avant ou après son départ
SROV5 – Amateur ou hacktiviste (SR5)	Rendre la plateforme indisponible par défi ou recherche de visibilité
SROV6 – Activiste	Nuire à l'image de la PME en divulguant des données
SROV7 – Organisation étatique	Espionnage

Atelier 3 – Parties prenantes

Catégories	Parties prenantes	Dépendance	Pénétration
Prestataire technique	PP1 - Prestataire d'infogérance	3	4
Hébergeur Cloud	PP2 - Hébergeur Cloud (IaaS)	4	3
Éditeur logiciel	PP3 - Éditeur de l'ERP/CRM	4	2
Fournisseur Cloud	PP4 - Fournisseur de messagerie	3	1
Prestataire financier	PP5 - Prestataire de paiement	3	1
Partenaire métier	PP6 - Expert-comptable	2	2
Intervenants externes	PP7 - Formateurs indépendants	4	3
Clients et Financeurs	PP8 - Clients / OPCO	4	1
Opérateur Télécom	PP9 - Fournisseur d'accès Internet (FAI)	4	1

Atelier 5 – Synthèse des risques

Index	Risque	Risque	Traitement	Sources de risque
R1	Une organisation criminelle paralyse la facturation et la relation client en chiffrant l'ERP et le CRM via le prestataire d'infogérance	Elevé	Réduire	SROV1 – Organisation criminelle
R2	Une organisation criminelle détourne des paiements en modifiant les coordonnées bancaires après hameçonnage	Elevé	Réduire	SROV2 – Organisation criminelle
R3	Un concurrent récupère le fichier clients et apprenants par l'intermédiaire d'un formateur indépendant	Modéré	Réduire	SROV3 – Concurrent
R4	Un ex-salarié exfiltre ou altère les données du CRM grâce à un compte non désactivé	Elevé	Réduire	SROV4 – Salarié ou ex-salarié
R5	Un amateur rend la plateforme indisponible en exploitant une vulnérabilité ou en saturant les services exposés	Modéré	Réduire	SROV5 – Amateur ou hacktiviste